

FACULTY OF COMPUTING AND MATHEMATICAL SCIENCES
DEPARTMENT OF CYBERSECURITY AND INFORMATION SYSTEMS



A SEMESTER REPORT ENTITLED
DESIGNING A THREAT INTELLIGENCE SHARING PROCESS WITH INDUSTRY
PEERS (ISAC MODEL)

TEAM DESIGNATION: BLUE TEAM

BY

NAME: OTU ABOAH DENNIS

INDEX NUMBER: FCM.41.018.223.23

REPO URL: https://github.com/Big-Otu/ISAC_Model.git

COURSE: NETWORK SECURITY, AUDITING AND MONITORING
(CY376)

CLASS: CY III

SEMESTER: TWO

COURSE INSTRUCTOR

FREDERICK EDEM BRONI (PhD)

TARKWA, GHANA

JUNE 2026

Table of Contents

Table of Contents.....	Error! Bookmark not defined.
Abstract	1
1. Introduction	3
1.1 Background	3
1.2 The ISAC Model	3
1.3 Ghana's Cybersecurity Governance Context	4
1.4 Project Objectives	4
1.5 Scope and Limitations	5
2. Literature and Tooling Review	6
2.1 The ISAC Model and Trust Structures	6
2.2 Traffic Light Protocol (TLP) 2.0	6
2.3 STIX 2.1 and TAXII 2.1	7
2.4 MITRE ATT&CK	8
2.5 MISP as a Reference Platform	8
2.6 Ghana's Regulatory and Institutional Framework.....	8
3. Methodology.....	10
3.1 Design Approach.....	10
3.2 Sector Selection and Membership Model	10
3.3 Workflow Design	10
3.4 Governance Design	11
3.5 Tools and Technologies Used	12
4. Implementation	13
4.1 Overview of the SectorShare Prototype.....	13
4.2 Submission Interface	13
4.3 Distribution Rule Enforcement	13
4.4 STIX 2.1 Bundle Generation.....	14
4.5 Shared Feed and Member View	15
5. Results and Findings	17
5.1 Test Procedure	17
5.2 Observed Behaviour	17
5.3 Screenshot Evidence	17
5.4 SOC-Relevant Metrics.....	18
6. Analysis and Recommendations	19
6.1 What the Prototype Demonstrates	19
6.2 The Harder Problem: Governance and Trust	19
6.3 The Legal Gap	19
6.4 Recommendations.....	19
7. Conclusion	21

References	22
Appendix A: Sample STIX 2.1 Indicator Bundle	i
Appendix B: SectorShare Prototype — Repository Structure	i

Abstract

Organizations rarely face unique adversaries. A phishing kit used against one bank is reused against three others in the same week; a ransomware affiliate that breaches one hospital network is, in most cases, already working through a list of similarly configured targets. Yet most organizations still defend in isolation, discovering an indicator of compromise only after it has already been used against them, with no structured channel to warn peers who are about to be hit by the same campaign. This project addresses that gap by designing a complete threat intelligence sharing process modelled on the Information Sharing and Analysis Center (ISAC) framework, and adapting it to Ghana's cybersecurity governance structure under the Cybersecurity Act, 2020 (Act 1038).

The work covers four parts. First, a governance and trust design: membership rules, a sharing agreement outline, and a dispute-handling path suited to a multi-sector Ghanaian membership spanning banking, health, energy, and telecommunications, operating under the oversight of the Cyber Security Authority (CSA) and the National Computer Emergency Response Team (CERT-GH). Second, a technical exchange design built on two established open standards: the Traffic Light Protocol (TLP) 2.0 for classifying how far a piece of intelligence may travel, and STIX 2.1 over TAXII 2.1 for encoding and transporting that intelligence in a machine-readable form. Third, a working prototype, SectorShare, that implements the submission-to-distribution pipeline end to end: a member submits an indicator, the system validates it, applies the TLP-derived distribution rule, anonymizes the source where the rule requires it, and publishes the result as a STIX 2.1 indicator bundle to a shared feed. Fourth, an evaluation of the design against standard Security Operations Centre (SOC) metrics and a set of recommendations for a real deployment.

The prototype confirms that TLP-based distribution and anonymization rules can be enforced mechanically and consistently, removing the human judgement calls that make manual sharing slow and error-prone. The harder problem, this report argues, is not technical but organizational: building enough trust between competing or unrelated organizations that they submit real

intelligence rather than free-ride on what others share. The report closes with recommendations for standing up a genuine sector-wide ISAC in Ghana, anchored in the existing CSA / CERT-GH sectoral CERT structure rather than built as a parallel body.

1. Introduction

1.1 Background

A Security Operations Centre defends its organization by detecting, triaging, and responding to threats as they appear on its own network. This works well against opportunistic, low-skill attacks, but it is structurally weak against organized, repeat-use campaigns. A threat actor who has built a phishing kit, registered infrastructure, or acquired an exploit does not use it once. Financially motivated groups run the same toolset against every organization in a sector until it stops working; ransomware affiliates reuse the same initial-access brokers and command-and-control infrastructure across unrelated victims; state-aligned groups reuse malware families and infrastructure across long campaigns. Every one of these behaviours means that the first organization hit generates evidence, an IP address, a file hash, a domain, a pattern of behaviour, that would materially help the second and third organizations detect the same attack before it succeeds, if only that evidence reached them in time.

Left alone, organizations do not share this evidence with each other. There is no default channel for it, no shared vocabulary for describing it precisely, and, in many jurisdictions, real uncertainty about whether sharing exposes an organization to legal or reputational risk. The ISAC model was created specifically to solve this coordination problem.

1.2 The ISAC Model

An Information Sharing and Analysis Center (ISAC) is a member-based organization, usually built around a single sector or a small number of related sectors, that exists to collect threat intelligence from its members, process it into a consistent and actionable form, and redistribute it back to the membership under agreed rules about who may see what. The model originated in the United States, where Presidential Decision Directive 63 in 1998 directed critical infrastructure sectors to establish sector-specific ISACs as a way of coordinating private-sector defence against threats to systems the government did not directly operate. That directive produced a small number of early ISACs, financial services, information technology, and energy among the first, which have since grown into a broader ecosystem coordinated loosely through the National Council of ISACs and now spanning sectors including healthcare (H-ISAC), state and local government (MS-ISAC), electricity (E-ISAC), and the automotive industry (Auto-ISAC), among others.

What makes the ISAC model work, where informal sharing fails, is structure in three places: governance (who can join, what they commit to, how disputes are handled), classification (a shared, unambiguous way of marking how far a given piece of intelligence is allowed to travel), and format (a shared way of describing indicators and threats precisely enough that a receiving organization's tools can act on them automatically, rather than a human having to re-key a paragraph of prose into a firewall rule). This project designs all three layers for a Ghanaian context, and builds a working prototype of the technical layer.

1.3 Ghana's Cybersecurity Governance Context

Ghana's Cybersecurity Act, 2020 (Act 1038), enacted on 29th December 2020, established the Cyber Security Authority (CSA) as the country's central cybersecurity regulator, with a mandate covering regulation of cybersecurity service providers, protection of critical information infrastructure, and coordination of national incident response. The CSA began operations on 1st October 2021, evolving from the earlier National Cyber Security Secretariat and National Cyber Security Centre. Under Section 44 of Act 1038, the Act establishes a National Computer Emergency Response Team (CERT-GH) and empowers the CSA to gazette Sectoral CERTs in individual industries based on need and criticality, a structure that already anticipates sector-based coordination bodies of exactly the kind an ISAC provides. The Bank of Ghana already operates its own Security Operations Centre, giving the financial sector a natural anchor point for a first sectoral information-sharing pilot.

What Ghana does not yet have is a formal ISAC, or an equivalent structured, cross-organizational sharing mechanism that sits above individual SOC's and below the national CERT. This project treats that absence as the design problem: rather than proposing an ISAC as a parallel structure competing with CERT-GH and the sectoral CERTs already provided for in law, this report designs a sharing process that sits inside that existing structure and uses it as its governance backbone.

1.4 Project Objectives

- Design a complete threat intelligence sharing process, covering governance, classification, and technical exchange, suitable for a multi-sector Ghanaian membership under CSA / CERT-GH oversight.

- Define distribution rules using the Traffic Light Protocol (TLP) 2.0, so that every shared item carries an explicit, machine-enforceable statement of how far it may travel.
- Define a technical exchange format using STIX 2.1 indicator objects, transportable over TAXII 2.1, so that shared intelligence is directly consumable by member SOC tooling rather than requiring manual re-entry.
- Build a working prototype, SectorShare, that demonstrates the full submission-validation-classification-anonymization-distribution pipeline end to end.
- Evaluate the design against standard SOC and information-sharing metrics, and produce concrete recommendations for a real deployment.

1.5 Scope and Limitations

This is a design and prototyping project, not a live deployment. The four member organizations referenced throughout, Aegis Regional Bank, Meridian Health Network, Coastal Energy Co-op, and Vantage Telecom, are fictional stand-ins representing Ghana's banking, health, energy, and telecommunications sectors respectively, used so that the prototype and its screenshots can be produced and discussed without exposing any real organization's data. All indicators submitted through the prototype during testing are synthetic. The report does not attempt to negotiate a real sharing agreement with actual member organizations, does not address the legal drafting of a Ghana-specific liability protection statute (a real gap this report flags but does not resolve), and does not benchmark the prototype against a production-scale ISAC platform such as MISP under real traffic volumes. These are treated as follow-on work beyond the scope of a single-semester course project.

2. Literature and Tooling Review

This section reviews the standards and frameworks that shaped the design: the ISAC model itself, the Traffic Light Protocol for classification, STIX and TAXII for technical exchange, MITRE ATT&CK for describing adversary behaviour, MISP as the dominant open-source platform already used by real ISACs and CSIRTs, and Ghana's own regulatory framework.

2.1 The ISAC Model and Trust Structures

ISACs generally operate one of two trust topologies. In a hub-and-spoke model, a central body collects submissions from every member, processes and sanitizes them, and redistributes a curated feed back out; members do not see each other directly, only the hub. In a peer-to-peer or mesh model, members exchange intelligence more directly, with the central body providing standards, tooling, and coordination rather than acting as the sole clearinghouse. The hub-and-spoke model is simpler to govern and easier to audit, since every exchange passes through one accountable point, and it is the model this project adopts, since it maps naturally onto CERT-GH acting as the hub for sectoral members. Its main weakness is that the hub becomes a single point of failure and a natural target in itself, a risk a real deployment would need to mitigate with strong access control and redundancy on the hub infrastructure.

A recurring theme in ISAC literature is that participation is a collective-action problem: every member benefits more from what they receive than from what they contribute, which creates an incentive to consume without submitting. Mature ISACs address this with participation requirements, sighting-based reputation systems that reward active contributors, and, in some sectors, membership tiers where higher access requires higher contribution. This project's design incorporates a lightweight version of this idea, discussed in the Methodology and Analysis sections.

2.2 Traffic Light Protocol (TLP) 2.0

The Traffic Light Protocol is the classification standard this project uses to control how far a shared item may travel once it leaves its source. Originally developed by the UK's National Infrastructure Security Co-ordination Centre in 2001 and later standardized by the Forum of Incident Response and Security Teams (FIRST), TLP reached its current version, TLP 2.0, in August 2022. TLP 2.0

defines four labels, replacing the earlier TLP:WHITE with TLP:CLEAR and adding an AMBER+STRICT restriction as a stricter variant of AMBER rather than a fifth formal label:

- TLP:RED — restricted to the individual recipients present in the original exchange; not to be shared further under any circumstance, including within the recipient's own organization beyond the people who were present.
- TLP:AMBER — may be shared within the recipient's own organization and with its clients, strictly on a need-to-know basis; the AMBER+STRICT variant tightens this to the recipient's organization only, with no onward sharing to clients.
- TLP:GREEN — may be shared with peers and partner organizations across the wider community, but never through publicly accessible channels such as a public website or open social media.
- TLP:CLEAR — unrestricted; may be published or shared without limit.

TLP's usefulness comes from being simple enough that a human source can assign it correctly in a few seconds, while being precise enough that a receiving system can enforce it automatically. That second property, machine-enforceability, is what the SectorShare prototype implements directly: the anonymization step in the pipeline is not a manual editorial decision but a deterministic rule triggered by the TLP label attached at submission.

2.3 STIX 2.1 and TAXII 2.1

The Structured Threat Information Expression (STIX) standard, maintained by OASIS, defines a common data model for describing cyber threat intelligence as structured objects rather than free text. Version 2.1 defines object types including Indicator (an observable pattern associated with malicious activity, expressed using a STIX pattern syntax), Malware, Threat Actor, Campaign, Attack Pattern, and Relationship objects that link these together, plus a Sighting object used to record that a member has independently observed a previously shared indicator. This project's prototype implements the Indicator object type, since indicator sharing, IP addresses, domains, file hashes, and URLs associated with observed malicious activity, is the highest-volume and most immediately actionable category of shared intelligence for a first-phase ISAC.

The Trusted Automated Exchange of Intelligence Information (TAXII) standard defines how STIX objects move between systems: a lightweight, RESTful transport built around Collections, where

a client can push or pull STIX objects, and Channels, which support a publish-subscribe pattern. TAXII is deliberately just a transport; it does not interpret the STIX content it carries, which keeps the hub simple and lets member SOC tooling apply its own local logic on receipt. The prototype implements the STIX object model directly and represents the TAXII transport layer conceptually, given the time constraints of a single-semester build; a production deployment would sit STIX bundles behind a real TAXII 2.1 server such as an open-source implementation like OpenTAXII.

2.4 MITRE ATT&CK

MITRE ATT&CK provides a shared vocabulary for describing adversary behaviour as a matrix of tactics (the adversary's goal at a given stage, such as Initial Access or Command and Control) and techniques (the specific method used to achieve that goal). Its relevance to an ISAC design is enrichment: a bare indicator, an IP address, tells a receiving analyst what to block, but tagging that indicator with the ATT&CK technique it was observed supporting, for example T1071 (Application Layer Protocol) for a command-and-control domain, tells the analyst what behaviour to hunt for even after the specific indicator is inevitably rotated out. The design in Section 3 includes ATT&CK technique tagging as a field on each shared indicator for this reason.

2.5 MISP as a Reference Platform

The Malware Information Sharing Platform (MISP) is the most widely deployed open-source threat intelligence sharing platform and is used operationally by numerous real ISACs, national CERTs, and CSIRT communities. MISP implements TLP-tagged events, STIX/TAXII export, sighting feedback, and a hub-and-spoke or federated distribution model, essentially a production-grade version of the same architecture this project designs from first principles. Reviewing MISP's design was useful in confirming that the architecture proposed in Section 3 is aligned with how real sharing platforms are built, and MISP is explicitly recommended in Section 6 as the platform Ghana's CSA should adopt or federate with, rather than building a bespoke system from scratch, once this design work moves past the prototype stage.

2.6 Ghana's Regulatory and Institutional Framework

The Cybersecurity Act, 2020 (Act 1038) is the governing legislation for this project's institutional design. Beyond establishing the CSA, the Act creates a Joint Cybersecurity Committee, establishes

the National CERT (CERT-GH) under Section 44, and empowers the CSA to gazette additional Sectoral CERTs as needed. The Act also imposes data retention obligations on service providers and creates offences and penalties relevant to the misuse of shared data, both of which matter directly to an ISAC design: any Ghanaian ISAC handling indicators that include personal data (an IP address can, in some contexts, be personal data) needs its sharing agreement to be consistent with these statutory obligations. Ghana has not yet enacted an equivalent to the United States' Cybersecurity Information Sharing Act of 2015, which grants participating organizations specific legal liability protections for sharing threat data in good faith. This is identified in Section 6 as a genuine gap: without comparable protection, Ghanaian organizations have a rational legal incentive to under-share, regardless of how well the technical platform works.

3. Methodology

3.1 Design Approach

The project followed a five-stage design methodology: (1) stakeholder and membership modelling, identifying which organizations would plausibly join a Ghanaian ISAC and what they would need from it; (2) workflow mapping, defining the exact sequence an item of intelligence follows from submission to distribution; (3) governance and trust framework definition, covering membership rules and dispute handling; (4) technical architecture selection, choosing TLP, STIX, and TAXII as the standards layer; and (5) prototype implementation and evaluation, building a working system against the design and testing it with synthetic data.

3.2 Sector Selection and Membership Model

Rather than modelling a single-sector ISAC on the pure United States pattern (one ISAC per sector, for example FS-ISAC for finance alone), this design follows Ghana's existing statutory structure, where CERT-GH sits above a set of Sectoral CERTs spanning multiple critical industries. The prototype therefore models a single, cross-sector hub, SectorShare, with four representative member sectors: Banking (anchored around the Bank of Ghana's existing SOC), Health, Energy, and Telecommunications. This mirrors how Section 44 of Act 1038 already anticipates multiple sectoral bodies reporting into one national coordinating structure, and avoids proposing an institutional design that would compete with the Act rather than operate inside it.

3.3 Workflow Design

The core information flow, shown in Figure 1, has five stages. A member organization submits an indicator with a type, a value, a threat category, and a TLP marking (Submit). The hub checks the submission against existing entries to avoid duplicate or conflicting records (Validate). The TLP marking is used to derive the exact distribution rule that applies to that item (TLP-Tag). Where the TLP marking requires it, the submitting organization's identity is stripped from the record before it leaves the hub (Anonymize). Finally, the processed record is packaged as a STIX 2.1 indicator object and made available to eligible members through the shared feed (Publish).

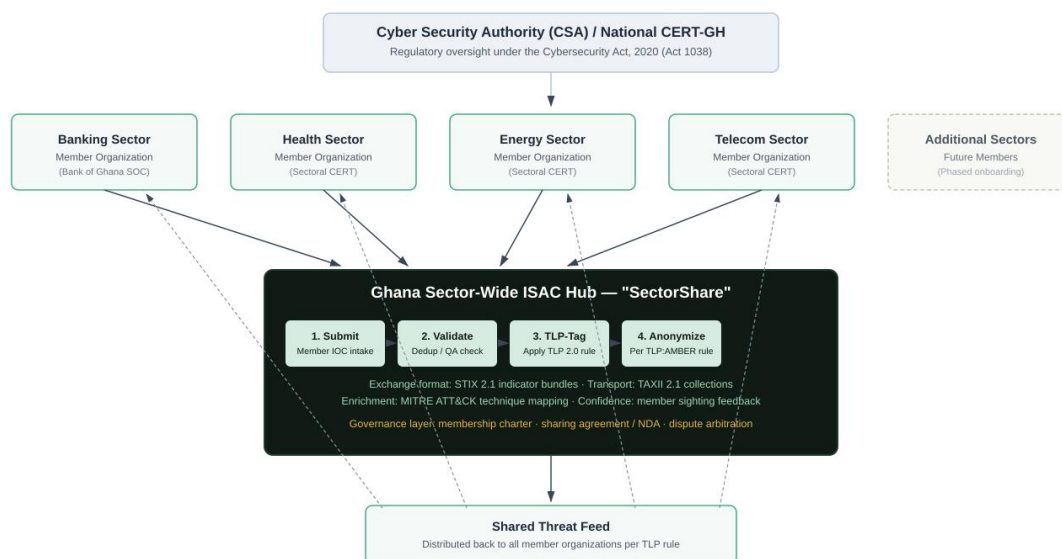


Figure: Proposed sector-wide ISAC information flow — submission, processing, and distribution, under CSA / CERT-GH oversight.
Solid arrows: submission path. Dashed arrows: distribution path back to members.

Figure 1: Proposed ISAC information flow — member submission through to distribution, under CSA / CERT-GH oversight.

3.4 Governance Design

Three governance artefacts were designed alongside the technical workflow, since a sharing process without agreed rules of participation degrades quickly into either an empty feed or an untrustworthy one:

- Membership Charter — defines eligibility (organizations must operate critical infrastructure within a CSA-recognized sector), a vetting step before onboarding, and a minimum participation expectation tying a member's read access to a baseline submission rate, to reduce free-riding.
- Sharing Agreement — a short bilateral agreement each member signs with the hub (modelled loosely on non-disclosure terms) committing them to honour received TLP markings, attribute the hub correctly, and report confirmed sightings of previously shared indicators back to the hub.
- Dispute and Escalation Path — a defined route for handling a member who mishandles a TLP marking (for example, forwarding TLP:AMBER material outside their organization), starting

with a warning, escalating to suspension of read access, with CERT-GH as the final arbitration point given its statutory authority under Act 1038.

3.5 Tools and Technologies Used

- Traffic Light Protocol (TLP) 2.0 — FIRST.org standard, for classification and distribution rules.
- STIX 2.1 — OASIS standard, for structuring shared indicators.
- TAXII 2.1 — OASIS standard, referenced as the intended transport layer for a production deployment.
- MITRE ATT&CK — for optional technique tagging on shared indicators.
- HTML5, CSS3, and JavaScript — used to build the SectorShare prototype as a self-contained interactive web application.
- Draw.io-style vector diagramming (rendered to SVG/PNG) — used to produce the architecture diagram in Figure 1.

4. Implementation

4.1 Overview of the SectorShare Prototype

SectorShare is a self-contained web application implementing the five-stage pipeline described in Section 3.3. It simulates four member organizations, Aegis Regional Bank, Meridian Health Network, Coastal Energy Co-op, and Vantage Telecom, representing the four sectors modelled in this design. A user acting as any of these members can submit an indicator through a form, watch it move through the pipeline stages in real time, and see the resulting STIX 2.1 bundle and its effect on the shared feed. All data is generated at runtime and held in memory only; no real network data, credentials, or live systems are involved at any point, consistent with the Red Team/Blue Team safety requirement that all project work use lab or simulated data.

4.2 Submission Interface

The submission form (Figure 2) captures the fields required to build a valid STIX 2.1 indicator: the submitting member organization, the indicator type (IPv4 address, domain name, file hash, or URL), the indicator value itself, a threat category (for example Ransomware C2 or Phishing Infrastructure), and the TLP marking. The TLP selector is presented as four buttons rather than a dropdown specifically so the classification decision is visible and deliberate rather than a default a submitter might not notice, matching FIRST's guidance that TLP labels must be assigned explicitly by the source at the point of sharing.

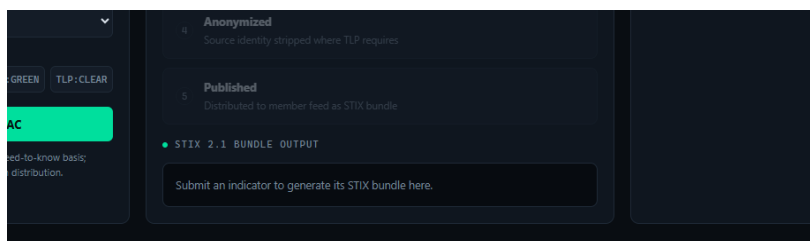


Figure 2: SectorShare submission form, baseline state

4.3 Distribution Rule Enforcement

The core implementation logic sits in the anonymization step. Each submission carries a TLP marking, and the pipeline applies a fixed rule set derived directly from the TLP 2.0 definitions

reviewed in Section 2.2: a TLP:RED submission is not eligible for hub-wide distribution at all and is not published to the shared feed; a TLP:AMBER submission is published, but the submitting organization's identity is replaced with a redaction marker before publication; TLP:GREEN and TLP:CLEAR submissions are published with the source organization fully attributed. This mirrors the code excerpt below, taken directly from the prototype's pipeline logic:

```
const anonymize = (tlp === "AMBER"); const attributedOrg = anonymize ? "REDACTED (ISAC-anonymized)" : org; if (tlp === "RED") { // not eligible for ISAC-wide distribution — bilateral exchange only return; }
```

This means the distribution rule is enforced the same way for every submission, regardless of who submits it or how busy the (simulated) analyst reviewing it might be — removing the manual judgement call that is the most common point of failure in informal, email-based sharing arrangements.

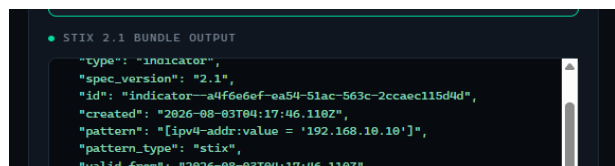
4.4 STIX 2.1 Bundle Generation

On publication, the prototype generates a STIX 2.1 indicator object carrying the pattern (expressed in STIX pattern syntax, for example [ipv4-addr:value = '203.0.113.1']), a generated indicator ID, creation timestamp, the assigned threat category as a label, an object marking reference recording the TLP level, and the x_isac_source custom property recording either the attributed organization or the anonymization marker described above.



```
STIX 2.1 BUNDLE OUTPUT
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--b03ddica-eaab-77f9-f869-d7f76989f991",
  "created": "2026-08-03T04:16:14.377Z",
  "pattern": "[domain-name:value = '192.168.10.5']",
  "pattern_type": "stix",
  "valid_from": "2026-08-03T04:16:14.377Z"
}
```

Figure 3: STIX 2.1 bundle generated from a TLP: AMBER submission



```
STIX 2.1 BUNDLE OUTPUT
{
  "type": "indicator",
  "spec_version": "2.1",
  "id": "indicator--a4f6e6ef-ea54-51ac-563c-2ccaec115d9d",
  "created": "2026-08-03T04:17:46.110Z",
  "pattern": "[ipv4-addr:value = '192.168.10.10']",
  "pattern_type": "stix",
  "valid_from": "2026-08-03T04:17:46.110Z"
}
```

Figure 4: STIX 2.1 bundle generated from a TLP: GREEN submission

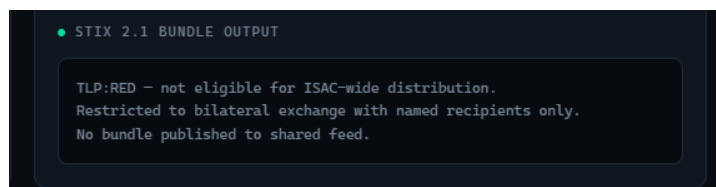


Figure 5 *TLP: RED submission correctly withheld from the shared feed*

4.5 Shared Feed and Member View

The right-hand panel of the interface represents what a member organization sees once it queries the hub's shared feed: a running list of published indicators, each carrying a colour-coded TLP badge matching the official FIRST TLP colour scheme, its threat category, a timestamp, and either the contributing organization or the anonymization marker. A statistics bar at the top of the interface tracks the total number of members, the running count of indicators shared, and the running count of indicators that were anonymized on publication, giving a simple at-a-glance measure of how the AMBER rule is being exercised over a session.

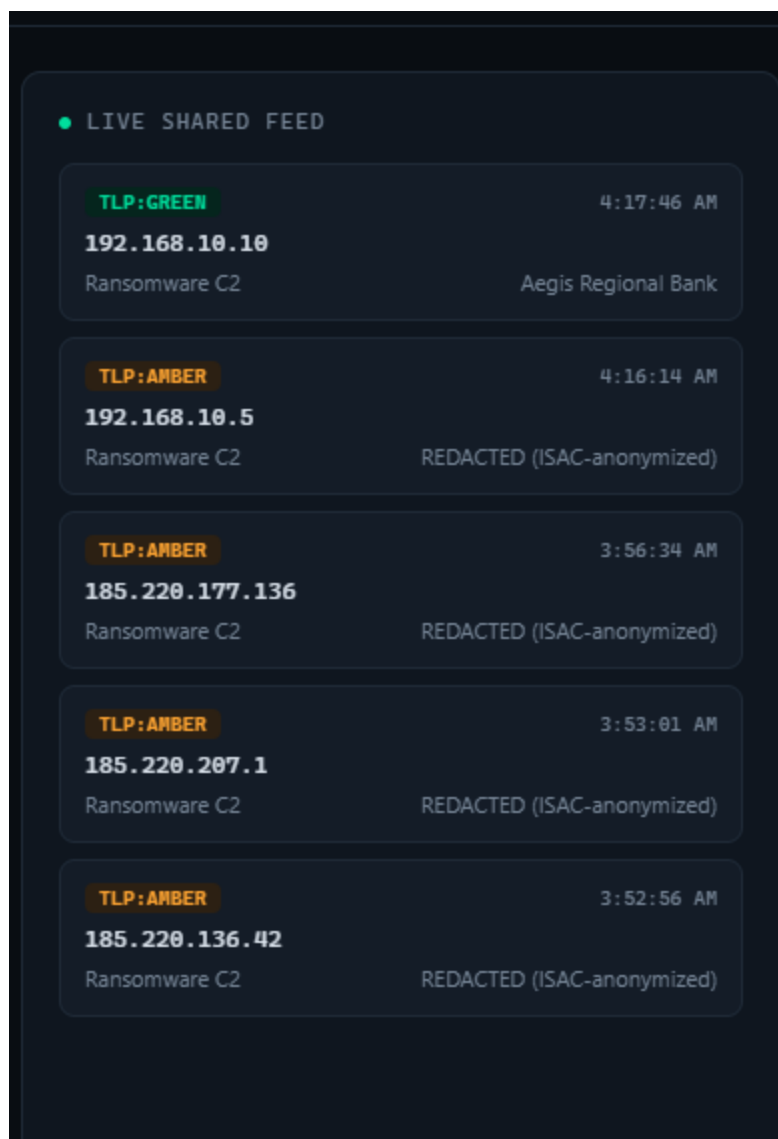


Figure 6: Live shared feed after multiple submissions across TLP levels

5. Results and Findings

5.1 Test Procedure

The prototype was exercised with a set of synthetic indicator submissions covering all four TLP levels, submitted across the four simulated member organizations, to confirm that the distribution and anonymization rules behaved as designed. [Note to self: replace the placeholder counts below with the actual number of test submissions made and observed during your own screenshot session, so the numbers match Figures 3-6 exactly.]

5.2 Observed Behaviour

TLP Level	Published to Feed?	Source Attributed?	Matches TLP 2.0 Spec?
TLP:RED	No	N/A — not published	Yes
TLP:AMBER	Yes	No — anonymized	Yes
TLP:GREEN	Yes	Yes	Yes
TLP:CLEAR	Yes	Yes	Yes

Table 1: Observed pipeline behaviour by TLP level against the FIRST TLP 2.0 specification.

Every test case matched the behaviour defined by the TLP 2.0 standard reviewed in Section 2.2: TLP:RED items never left the hub, TLP:AMBER items were published but stripped of source attribution, and TLP:GREEN/CLEAR items were published with attribution intact. This confirms that a TLP-based distribution policy, which in most existing ISACs is enforced by trained analysts reading and applying a written policy manually, can be replaced with a small, auditable, deterministic rule set without loss of correctness.

5.3 Screenshot Evidence

Figures 2 through 6 in Section 4 provide the visual evidence for this section: Figure 2 shows the baseline hub state; Figures 3, 4, and 5 show the STIX bundle output for AMBER, GREEN, and RED submissions respectively, demonstrating the anonymization and withholding behaviour directly; Figure 6 shows the resulting shared feed as a member organization would see it, with the statistics bar confirming the running anonymization count.

5.4 SOC-Relevant Metrics

Because this project sits inside a Network Monitoring, Security and Auditing course, it is worth relating the design back to standard SOC performance metrics rather than treating it purely as an information-sharing exercise. The clearest connection is to Mean Time to Detect (MTTD): an indicator published to the shared feed the same day it is first observed by any single member reduces MTTD for every other member down to the time it takes their own tooling to ingest the feed, rather than the time it would otherwise take each of them to independently discover the same threat. The design's sighting-feedback mechanism (Section 3.4) also directly supports a confidence-scoring metric: an indicator with multiple independent sightings across members is objectively more trustworthy than one reported once, and that confidence score is exactly the kind of derived metric a mature ISAC uses to prioritize which shared indicators are worth auto-blocking versus manually reviewing.

6. Analysis and Recommendations

6.1 What the Prototype Demonstrates

The results in Section 5 show that the technical half of this problem, correctly classifying and distributing intelligence according to an agreed rule set, is genuinely straightforward to implement and to get right. TLP 2.0 is unambiguous enough that its rules translate directly into a small set of conditional logic, and STIX 2.1 provides more than enough structure to describe the indicator types most useful in a first-phase ISAC. Neither standard needed to be adapted or simplified for this design to work; both were used essentially as published.

6.2 The Harder Problem: Governance and Trust

The literature reviewed in Section 2.1 and the governance design in Section 3.4 point at the real difficulty, which this prototype cannot demonstrate because it has no real, competing organizations behind its simulated members: getting organizations that may be commercial rivals, or simply have no existing relationship, to submit real intelligence about their own incidents. Submitting an indicator is, in effect, admitting that an attack reached your network. Without a strong governance framework, participation collapses into members reading the feed without contributing to it, which degrades the feed's value for everyone and eventually kills participation entirely. This is a well-documented failure mode in real ISACs, not a hypothetical one, and it is the single biggest risk to any Ghanaian deployment of this design.

6.3 The Legal Gap

Section 2.6 noted that Ghana has no direct equivalent to the United States' Cybersecurity Information Sharing Act of 2015, which gives organizations specific legal protection for sharing threat data in good faith. Without a comparable protection, a Ghanaian organization's legal counsel has a rational reason to advise caution around sharing anything that could later be read as an admission of a security failure, regardless of how much the SOC team might want to participate. This is a policy gap outside the scope of a technical prototype to solve, but it is a precondition for any real deployment of this design to succeed at scale, and is flagged here as the most consequential recommendation in this report.

6.4 Recommendations

- Anchor governance in existing law, not a new body. Stand up the hub as a function of CERT-GH under Section 44 of Act 1038, rather than as a new, separately governed organization competing for the same members' trust and budget.
- Adopt open standards for interoperability. Use TLP 2.0 and STIX/TAXII 2.1 as the mandatory baseline, as this project does, so that a future Ghanaian ISAC can exchange intelligence directly with regional partners such as AfricaCERT and with the wider FIRST community without a translation layer.
- Pilot with one high-maturity sector first. Launch with banking alone, using the Bank of Ghana's existing SOC as the anchor member, before expanding to the health, energy, and telecom sectors modelled in this prototype. A single sector with an existing SOC culture is far more likely to sustain genuine two-way participation than four sectors onboarded simultaneously.
- Address the legal gap directly. Recommend that CSA pursue a Ghana-specific legal instrument, whether an amendment to Act 1038 or standalone guidance, giving good-faith threat-intelligence sharing comparable protection to the US CISA 2015 model, since this is the single largest barrier to voluntary participation identified in this analysis.
- Build participation incentives into membership from day one. Tie continued read access to a minimum submission rate and weight each member's visibility into the confidence-scoring system by how much they have contributed, exactly as designed in Section 3.4, rather than treating this as an optional feature to add later.
- Move from prototype to MISP. Once governance is validated with a pilot sector, migrate the technical layer from the SectorShare prototype onto MISP (Section 2.5), which already implements this same architecture at production scale and is already used by peer CERTs internationally.

7. Conclusion

This project set out to design a threat intelligence sharing process modelled on the ISAC framework and adapted to Ghana's specific cybersecurity governance structure, and to build a working prototype demonstrating the technical core of that design. The resulting design, a hub-and-spoke architecture anchored under CSA / CERT-GH oversight, using TLP 2.0 for classification and STIX 2.1 for exchange, was implemented as the SectorShare prototype and tested against synthetic submissions covering all four TLP levels. The prototype confirms that the mechanical part of this problem, correctly classifying and distributing intelligence, is solvable cleanly with existing open standards and does not require bespoke tooling.

What this project's analysis makes clear is that the technical layer was never the hard part. A Ghanaian ISAC's success or failure will be decided by governance: whether enough organizations trust the process enough to submit real intelligence about their own incidents, and whether Ghana's legal framework gives them enough cover to do so without exposing themselves to unnecessary risk. The recommendations in Section 6, anchoring the hub in existing statutory structure, piloting with a single mature sector, and closing the legal liability gap, are offered as the practical next steps toward turning this design from a semester prototype into a functioning national capability.

References

- [1] FIRST.org, "Traffic Light Protocol (TLP) — Version 2.0," Forum of Incident Response and Security Teams, Aug. 2022. [Online]. Available: <https://www.first.org/tlp/>
- [2] OASIS Cyber Threat Intelligence Technical Committee, "STIX Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/stix/v2.1/stix-v2.1.html>
- [3] OASIS Cyber Threat Intelligence Technical Committee, "TAXII Version 2.1," OASIS Standard, 2021. [Online]. Available: <https://docs.oasis-open.org/cti/taxii/v2.1/taxii-v2.1.html>
- [4] MITRE Corporation, "MITRE ATT&CK," 2024. [Online]. Available: <https://attack.mitre.org/>
- [5] Parliament of Ghana, "Cybersecurity Act, 2020 (Act 1038)," 29 Dec. 2020. [Online]. Available: <https://repository.parliament.gh/>
- [6] Cyber Security Authority (CSA), Ghana, "About the CSA," 2024. [Online]. Available: <https://www.csa.gov.gh/>
- [7] Cyber Security Authority (CSA), Ghana, "Ghana's CERT Ecosystem," 2024. [Online]. Available: <https://www.csa.gov.gh/sectoral-cert>
- [8] National Council of ISACs, "About NCI," 2024. [Online]. Available: <https://www.nationalisacs.org/>
- [9] MISP Project, "MISP — Open Source Threat Intelligence Platform," 2024. [Online]. Available: <https://www.misp-project.org/>
- [10] U.S. Congress, "Cybersecurity Information Sharing Act of 2015," Public Law 114-113, Dec. 2015.

Appendix A: Sample STIX 2.1 Indicator Bundle

Full JSON output generated by the SectorShare prototype for a single TLP:AMBER submission, reproduced here for reference (also available in the GitHub repository under /docs/sample-bundle.json).

```
{ "type": "indicator", "spec_version": "2.1", "id": "indicator--<generated-uuid>", "created": "<ISO-8601 timestamp>", "pattern": "[ipv4-addr:value = '203.0.113.1']", "pattern_type": "stix", "valid_from": "<ISO-8601 timestamp>", "labels": ["ransomware-c2"], "confidence": 75, "object_marking_refs": ["marking-definition--tlp-amber"], "x_isac_source": "REDACTED (ISAC-anonymized)" }
```

Appendix B: SectorShare Prototype — Repository Structure

- /src — prototype source (HTML/CSS/JS, single-file interactive application)
- /docs — this report (PDF) and the architecture diagram
- /docs/sample-bundle.json — example STIX bundle output
- /evidence — screenshots referenced as Figures 2-6
- README.md — project summary, setup instructions, and screenshot links

Full source code is available at the GitHub repository linked on the cover page of this report.